ACME Technologies

ASSESSMENT TASK 2 – CASE STUDY

VU23305 – CONFIGURE SECURITY DEVICES FOR AN ORGANISATION
ICTNWK544 – DESIGN AND IMPLEMENT A SECURITY PERIMETER FOR ICT NETWORKS

OFFICIAL

Contents

(A1) - Scope 3
(A2) – Existing Network Topology 4
..... 4
(A3) – IPSec VPN Documentation 4
(A4) – Security Policy Updates 5
(A5) – Vendor VPN Comparison 7
(i) Vendor 1 7
(ii) Vendor 2 7
(A6) – VPN Compatible devices 7
(A7) – Redesigned Network Topology - VPN 8
(A8) – Virtual Network Security Technologies 8
(B2) – Final Network Design 9
..... 9
(i) Comments 10
(B3) – Configure Basic settings on the ASA device 10
(B4) – Configure the DHCP service on the ASA device for the internal network. 11
(B5) – Configure routing on the ASA 13
(B6) – Configure OSPF routing for HQ, Internet, Branch and External routers for connectivity testing. 13
(B7) – Configure Secure Network Management for the ASA device. 14
(B8) – Configure NAT Service for the ASA device for both INSIDE and DMZ networks. 15
(B9) – Configure ACL on the ASA device to implement the Security Policy. 16
(B10) – Configure Layer 2 Security on a Switch 17
(B11) – Configure a Site-to-Site IPSEC VPN between the HQ and Branch routers. 19
(B12) – VPN Monitoring 22

Part A - Documentation

(A1) - Scope

This project purpose is to review and update the current network topology of Car1 company's HQ and branch office networks and document the network security recommendations based on their requirements. During the project we will improve the overall network security based on the current vulnerabilities we identified, suggest new technologies to be used, ensure safe data transmission between offices, and provide controlled access to the public services which are hosted in the DMZ. Along this project, we will configure a secure network perimeter, implement VPN connectivity, and enforce access control policies to minimise the risk of cyber security threats.

The main parts of the projects are:

1. Securing the communication by implementing IPSec VPN between the HQ and branch offices which will ensure encrypted communication and prevent cybercriminals to view transited data.

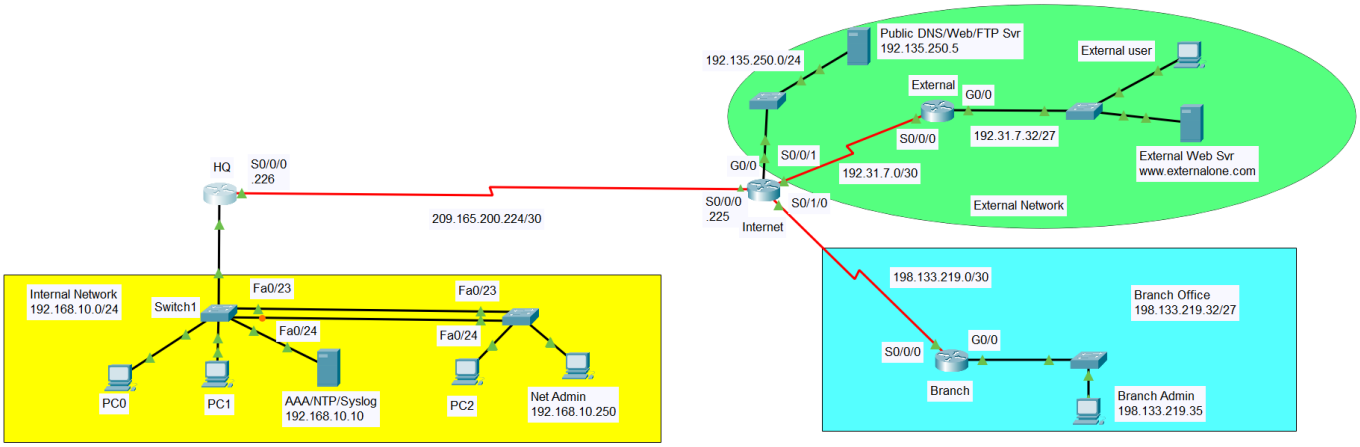
2. The implementation of DMZ for public services such as web and DNS servers with strict access control policies to ensure the protection of the internal network.

3. The implementation of layer 2 security on switches and network devices to prevent unauthorized access and data breaches which could occur with threats like MAC address spoofing and VLAM hopping.

4. Configure ASA firewall to monitor and limit traffic across the network to ensure the security of the internal and external connectivity.

5. Updating the security policies to make sure they are up to date with the most relevant standards and best practices

(A2) – Existing Network Topology



(i) Comments

- The HQ network device is directly connected to the internal network, external network and branch office without separation.
- There is no switch with port-based security and STP security and there is no ASA device connected to the HQ network device to secure and segment both internal, external and branch office networks.
- There is not any DMZ network which contains the public services to be accessed from the internet and separate them from the different company's networks.

(A3) – IPSec VPN Documentation

The IPSec VPN configuration will provide a secure and encrypted tunnel between the Cae1 Company's HQ and branch office. It will ensure the data confidentiality, integrity, and authenticity, and provide monitoring tool to analyse interesting traffic. There are 2 phases for the configuration:

Phase 1 – ISAKMP: will provide a secure tunnel between endpoints (**HQ router and Branch**). The encryption level will be high with the **AES-256** key exchange. The **hashing algorithm SHA-1** will be configured as well to ensure data integrity during the negotiation process. Furthermore, the authentication method will be pre-shared key and the **Diffie-Hellman group** will be **number 2** for balancing the security and performance for key exchange.

Phase 2 – IPSec: Will provide a secured transmission of data over the VPN by encrypting and encapsulating data packets. It will be configured on the HQ router and the branch router with **the transoformSET VPN-SET – esp-aesesp-sha-hmac** as the integrity algorithm which going to protect the data transmitted over a VPN. The **encrypted networks** will be as the following:

209.165.200.240/28
198.133.219.32/27

The **PeerIP addresses** will be as the following:

198.133.219.2
209.165.200.226

The CryptoMap name will be **"VPN-MAP"** and the SA Establishment will be **ipsec-isakmp** for using the secure tunnel which was established during phase 1.

OFFICIAL

(A4) – Security Policy Updates

1. Purpose:

This security policy is to safeguard Car 1 company's data and resources by securing the network operations. The policy should be known by the employees, contractors and any authorized users so they can use best practices and handle, use, and protect sensitive information.

Goals:

- Preventing unauthorized access, modification, or misuse of information.
- Ensuring the company's confidentiality, integrity, and availability.
- Having risk management in place with incident response plans.
- Ensuring compliance with most recent regulatory, legal and industry standards.
- Having physical and digital security controls to protect assets.
- Monitoring security incident regularly to ensure incidents are addressed and mitigated regularly.

Information Covered:

- Digital information across systems (software, hardware, and network infrastructure).
- Laptops and mobile devices
- Recording devices such as CCTV systems.

2. Security Policy:

All users of Car 1 company must follow the following policies to ensure the security of the company assets:

2.1 **Access Control and Authentication**

- Authorised Access: The car1's systems will only be accessed by authorized users who require to perform their job by accessing the system. Every user must have a unique user ID and a strong password based on the password policy requirements.
- NFA: In case VPN access and remote logins are required, it is important to use MFA for an additional layer of security.
- Accountability: Users should not share personal and private information without considering if the owner of the information agreed to share it, the risks in case the information is lost or accessed by the wrong person, and the security of the information in transit. Furthermore, the Authorised user identity must not be shared and should comply with the company's password policy.

2.2 **Acceptable use of information system**

- The information systems of the company must be used with responsibility and in a lawful manner.
- The systems should not be used for personal activities which can interfere with the company operations.
- The access for sensitive data will be provided for authorized users only, and the data should not be copied or transmitted without a proper permission and best practices.

2.3 **Data Protection and Handling:**

- The data will be encrypted both at rest and transit. The data from Branch to the HQ and vice versa will be transmitted over IPSec VPN using AES-256, ensuring the security of the communications.
- The company will backup the data regularly to ensure that data can be restored quickly in case of a loss.
- Information which is no longer in use must be deleted or destroyed. This includes physical documents and digital files.

2.4 **Incident Reporting and Response**

- Unusual activities and security incidents must be reported straight away to the IT security manager. Security event could be: Unauthorised access attempts, malware detection, and data breaches.
- Every incident must be investigated by the incident response team for handling potential threats, assessing the impacts, and mitigate it.
- Every incident will be revied after investigation, to evaluate the effectiveness of the response action to make sure that future incident response will be improved consistently.

2.5 **Network and Endpoint Security**

- All networks (DMS, Internal, external, and branch) are segmented to be able to limit access between sensitive data along with the ASA Firewall which got access control in place between the networks.
- System logs will be monitored regularly to ensure compliance with all policies and to be able to detect security incidents.

2.6 **Physical Security**

- Authorised personnel only will be allowed to access server rooms or data centers. Physical security will be in place including badge readers, CCTV monitoring, and security guards.
- Visitors must be monitored and sign in and out to make sure secured areas are safe.

The company will be able to take legal actions and investigate individuals which might breach this policy, including involving the police.

3. Policy Ownership

The IT security manager has the responsibility for maintaining and updating this policy, provide training, and view security compliance. The heads of the departments are responsible for enforcing this policy.

A. Appendix: Subsidiary Policies

Please refer to the following policies for more details:

1. Acceptable Use Policy
2. network Password Policy
3. VPN Access Policy
4. Network Connection Policy
5. Incident Response Policy
6. Data Retention and Disposal Policy

(A5) – Vendor VPN Comparison

(i) Vendor 1

- Fortinet – FortiClient VPN – is a VPN which working with FortiGate Firewalls, supporting IPSec VPN protocols and SSL protocols. It can also support ASA device which might require more configurations. FortiClient VPN provided integrated security features such as antivirus, web filtering, AES encryption, and MFA. Also, the user interface is considered friendly. This product is high in cost but offering better pricing for long term use and got solid support from Fortinet. Overall, FortiClient VPN is a great solution for organizations using Fortinet security solutions across most of their environments.

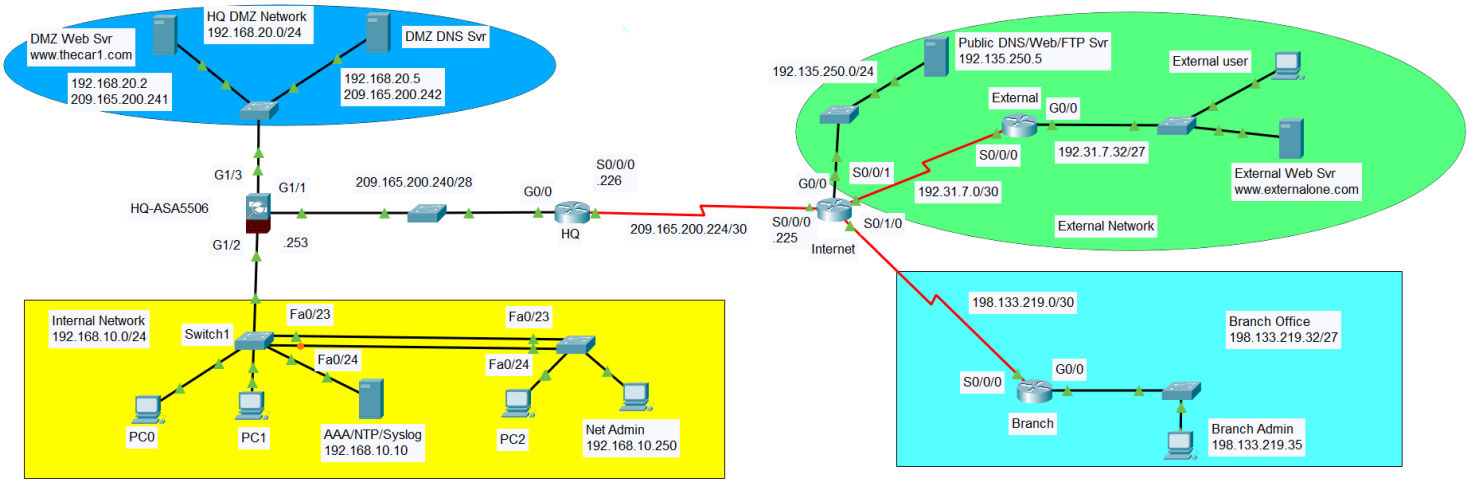
(ii) Vendor 2

- Cisco – AnyConnect VPN – is a popular solution that offers large range of security features and good scalability. It provides authentication methods such as SSO and MFA. Also, it is working well with different operating systems and devices, which can be beneficial for large organizations that are using many environments. Due to its great integration with the ASA device, less configuration is required for IPSec VPN compared to FortiClient VPN. It has security features such as AES encryption, endpoint compliance checks and split tunneling. The cost can be moderate to high, depending on the licensing. Overall, it has great performance capabilities, comprehensive Cisco support and it is ultimate for large enterprise environments which are using different vendors for security solutions.

(A6) – VPN Compatible devices

Device/Technologies	Description
Cisco ASA 5506-X Firewall	This is a firewall device which supports IPSec, SSL VPN, and provides advanced VPN security
Cisco ISR 4000 Series Router	Integrating with VPN including IPSec support and high-performance routing
PA-220 Firewall of Palo Alto Networks	Provided SSL VPN support including advanced threat detection
FortiGate 60E Firewall of Fortinet	Supporting IPSec and SSL VPN and offer deep inspection
Netgear Nighthawk R7000 Router	Got a built-in VPN
Juniper Networks SEX320 Router	Supports IPSec VPN, including strong encryption and firewall capabilities

(A7) – Redesigned Network Topology - VPN



(A8) – Virtual Network Security Technologies

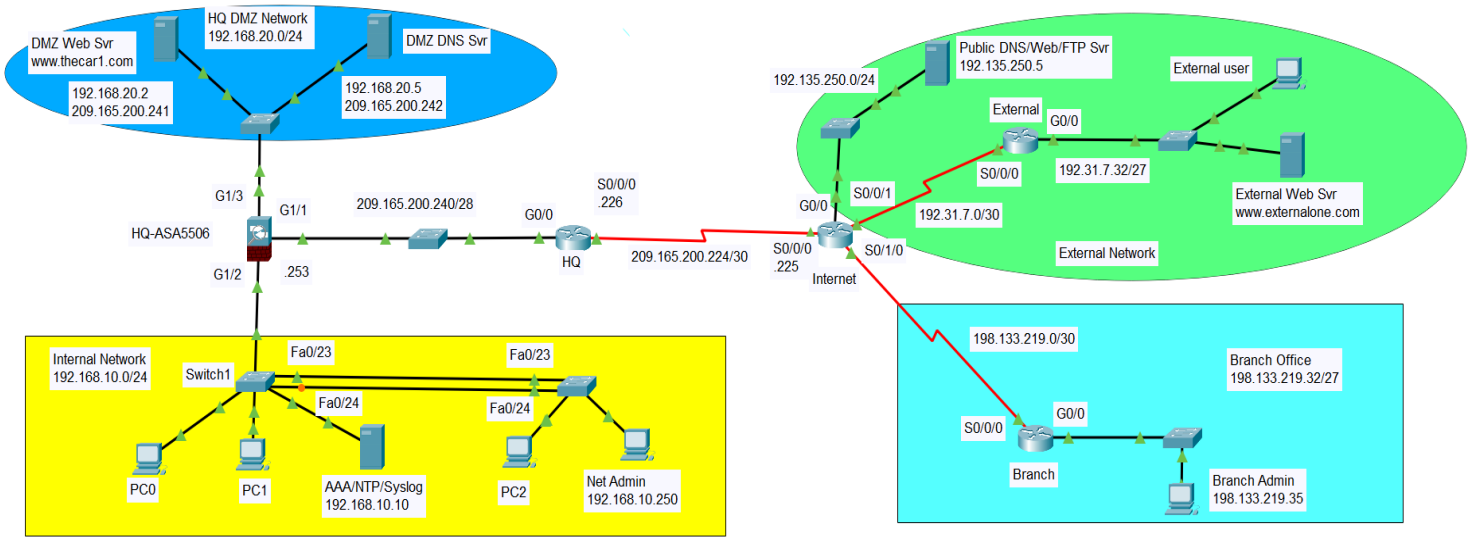
Vendor	Technology	End point	Features	Benefits
Palo Alto Networks	IDPS	Network devices, VPN gateways	Deep packet inspection, anomaly detection	Helping to prevent attacks against networks by monitoring and blocking malicious traffic
Cisco	VPN	Workstations, mobile devices	IPSec and SSL encryption and MFA	Securing remote access and encrypting connections
Zscaler ZTNA	ZTNA	Computers, mobiles	Identify verification, least-privilege access	Reduce the possibilities of attacks, limiting endpoint access to resources
Forcepoint	DLP	Workstations, network storage	Data encryption and monitoring content	Preventing the risk of data leaks from the endpoints, securing sensitive data, and comply with data regulations.
CrowdStrike Falcon	EDR	Computers, servers	Threat detection, AI behavior analysis	Threat detection and response, minimal impact on endpoints for smooth performance

OFFICIAL

Part B – Configure in Packet Tracer

(For every screenshot that is required, please provide a full window screenshot of the configurations with your name and student id visible in a notepad document). Your PC date and time should be visible.

(B2) – Final Network Design



OFFICIAL

(i) Comments

- DMZ network was added to the topology. DMZ contains the public services to be accessed from the internet and separate them from the different company's networks.
- ASA device was added to improve the security of the networks by adding AAA authentication, NAT services and ACL. ASA device combines firewall, antivirus, intrusion prevention and VPN which could enhance the security of the company.
- The NAT will hide the internal IPs of the DMZ and translate them to a public IP.
- The switch connected to the ASA device before the external branch networks, will help segmenting the network further and add security layer 2.
- VPN service (IPSec) will be implemented and add more security while helping monitoring the interesting traffic.

(B3) – Configure Basic settings on the ASA device

a) Configure the domain name as thecar1.com.



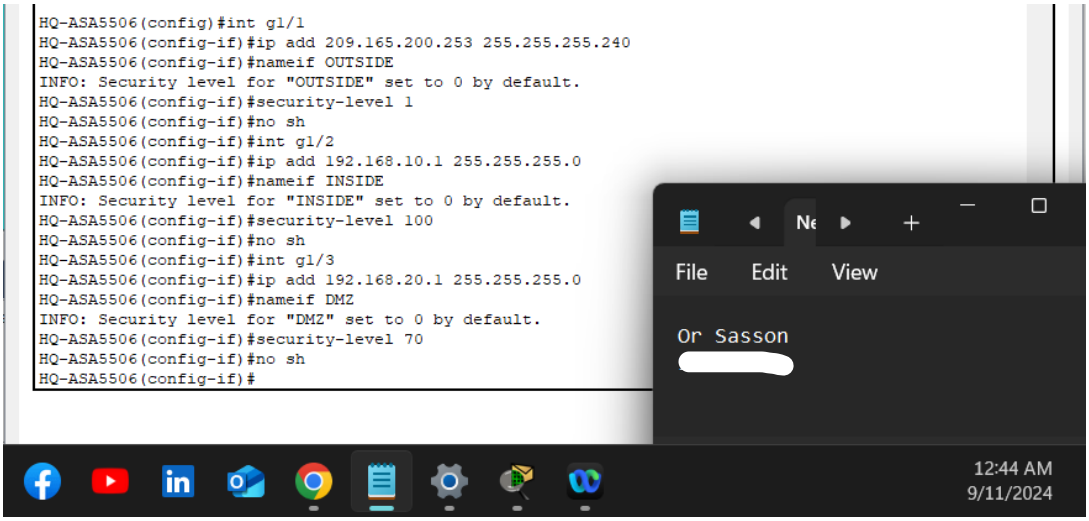
b) Configure the hostname as HQ-ASA5506.



c) Configure the INSIDE, OUTSIDE, and DMZ interfaces with the following:

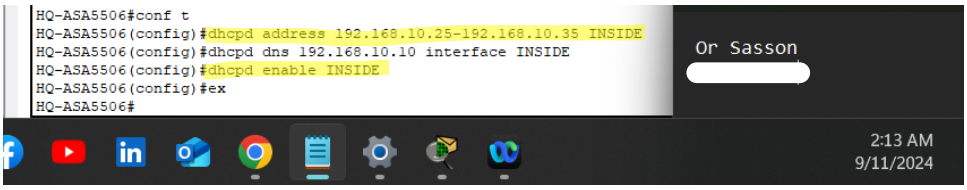
i. IP address 209.165.200.253/28, nameif OUTSIDE, security-level 1, assign to G1/1
ii. IP address 192.168.10.1/24, nameif INSIDE, security-level 100, assign to G1/2
iii. IP address 192.168.20.1/24, nameif DMZ, security-level 70, assign to G1/3

OFFICIAL

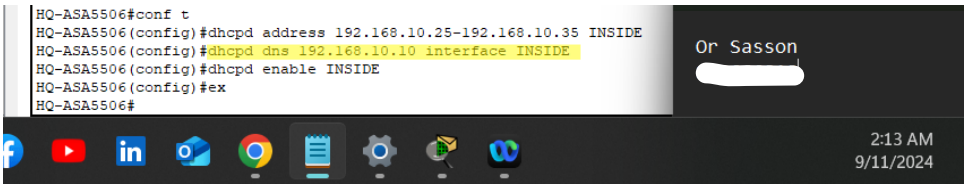


(B4) – Configure the DHCP service on the ASA device for the internal network.

a) The DHCP pool is 192.168.10.25 - 192.168.10.35.

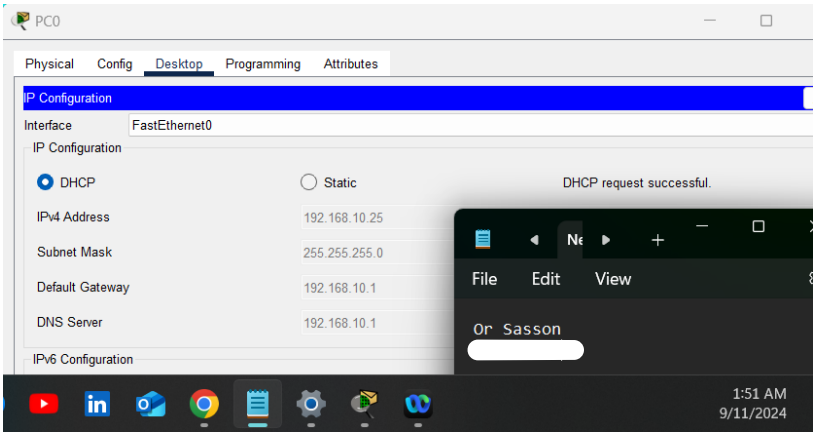


b) The DHCP service should provide DNS server (AAA/NTP/syslog server) information.



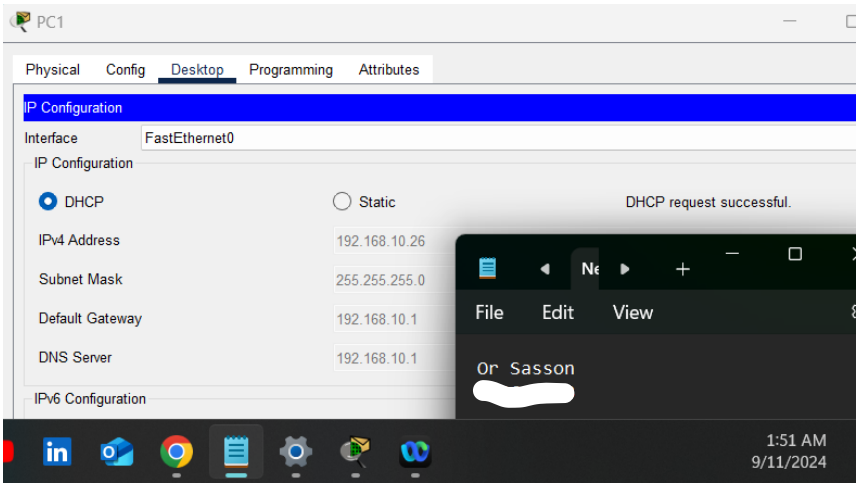
c) PC0, PC1, and PC2 should receive their addresses over DHCP.

PC0 obtained the IP address from the DHCP pool on the ASA device

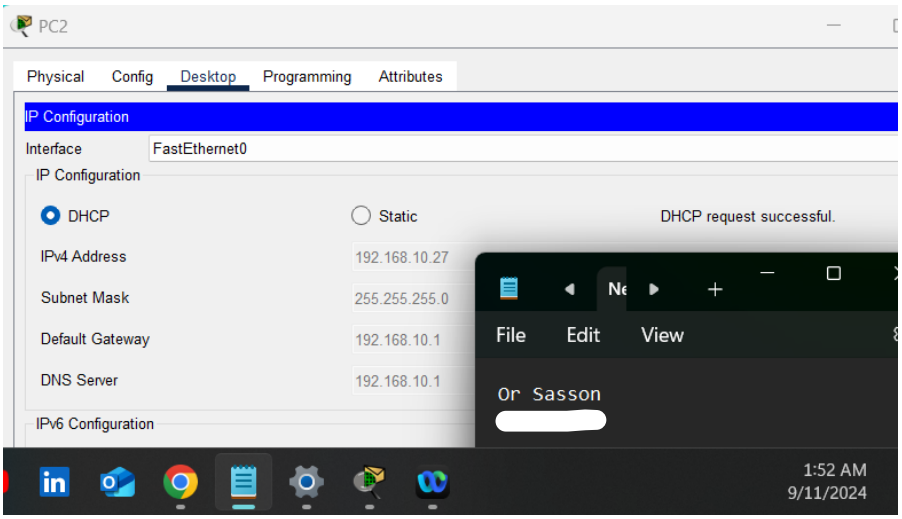


OFFICIAL

PC1 obtained the IP address from the DHCP pool on the ASA device



PC2 obtained the IP address from the DHCP pool on the ASA device



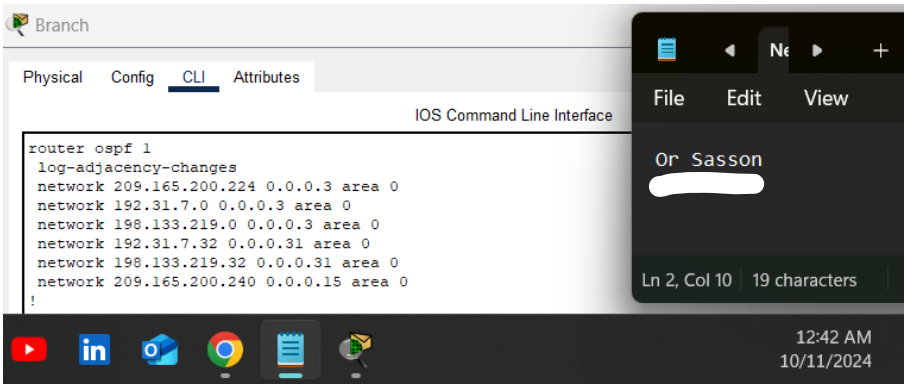
OFFICIAL

(B5) – Configure routing on the ASA

Configure a default route that will enable hosts on the HQ INTERNAL and DMZ networks to communicate with outside hosts. Use the IP address of the HQ router interface as the gateway interface.

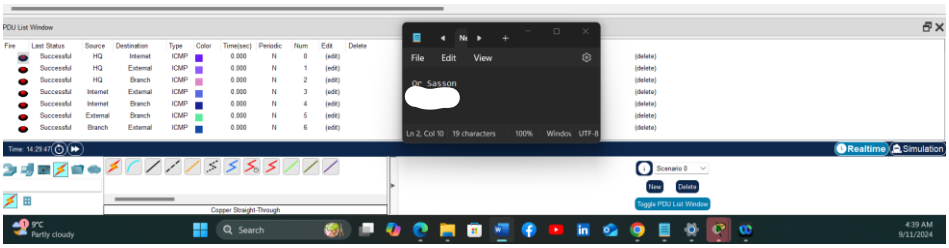


(B6) – Configure OSPF routing for HQ, Internet, Branch and External routers for connectivity testing.



a) Show screenshots of successful ping between routers. Troubleshoot if ping fails.

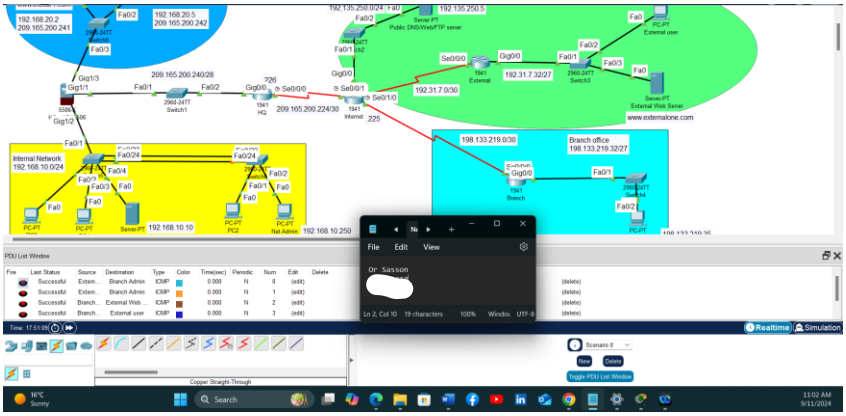
All 4 routers can communicate with each other. Ping is successful



b) Show screenshots of successful ping between end devices from External Network to the Branch office network. Troubleshoot if ping fails.

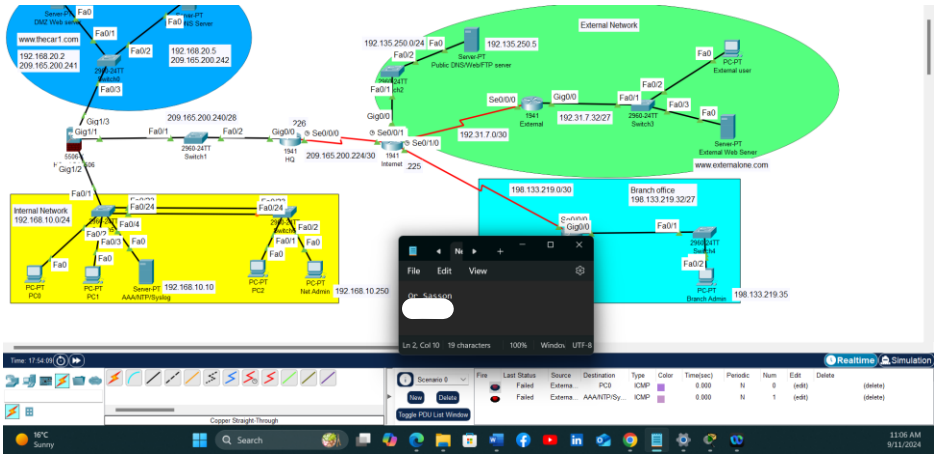
OFFICIAL

The ping between external end devices to the branch end device was successful as expected.



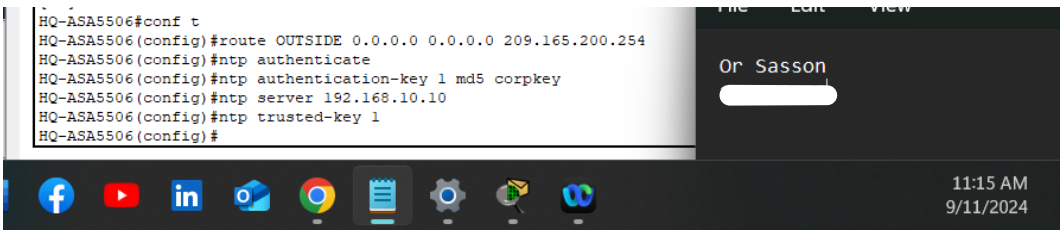
c) Show screenshot of ping between External user PC to any 2 end devices on the Internal Network. The pings should fail.

The ping between external user to PC0 and AAA/NTF/Syslog server failed as expected



(B7) – Configure Secure Network Management for the ASA device.

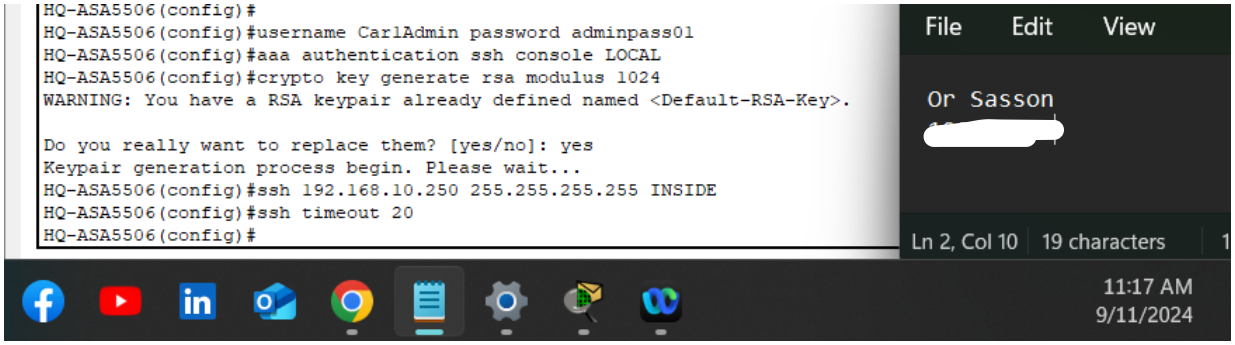
a) Configure the ASA with NTP and AAA:
   i. The ASA is a NTP client to the AAA/NTP/Syslog server.
   ii. Enable the authentication to the ASA.
   iii. The authentication key is key 1 with the password corpkey.



OFFICIAL

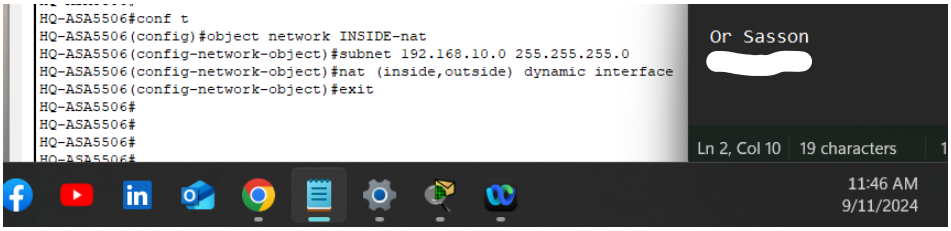
b) Configure AAA and SSH.

i. Configure the ASA device with AAA authentication using the username of Car1Admin and password of adminpass01.
ii. Configure AAA to use the local database for SSH connections to the console port.
iii. Generate a RSA key pair to support with modulus size of 1024 bits.
iv. Configure HQ-ASA5506 to accept SSH connections only from the Net Admin workstation.
v. Configure SSH session timeout to be 20 minutes.

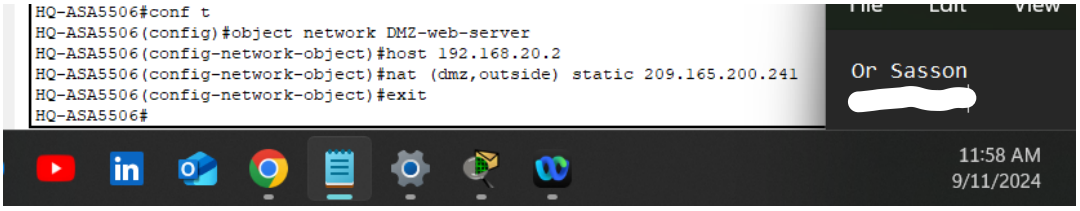


(B8) – Configure NAT Service for the ASA device for both INSIDE and DMZ networks.

a) Create a network object called INSIDE-nat with subnet 192.168.10.0/24 and enable the IP addresses of the hosts in the internal network to be dynamically translated to access the external network via the outside interface.



b) Create a network object DMZ-web-server to statically translate the DMZ web server internal IP address to the outside public IP address 209.165.200.241.



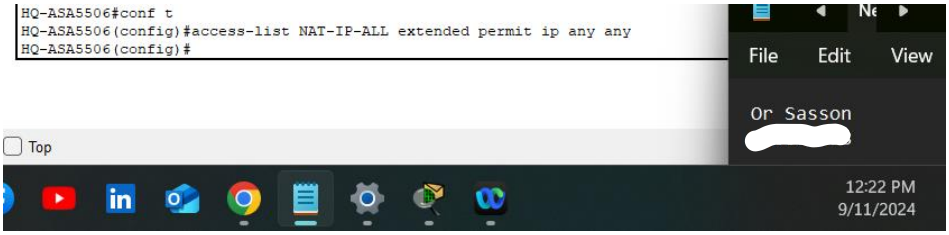
c) Create a network object DMZ-dns-server to statically translate the DMZ DNS server internal IP address to the outside public IP address 209.165.200.242.

OFFICIAL

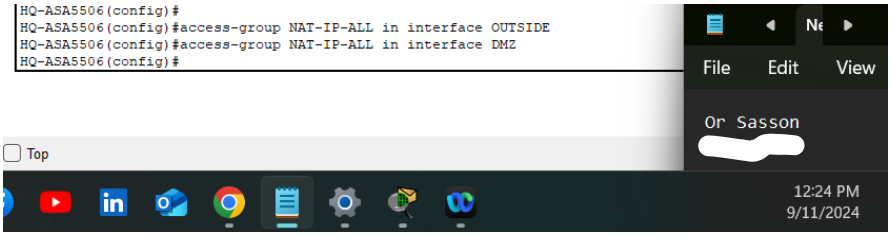


(B9) – Configure ACL on the ASA device to implement the Security Policy.

a) Configure a named extended ACL to permit inside hosts to be translated to the pool of outside IP addresses. Name the ACL NAT-IP-ALL.

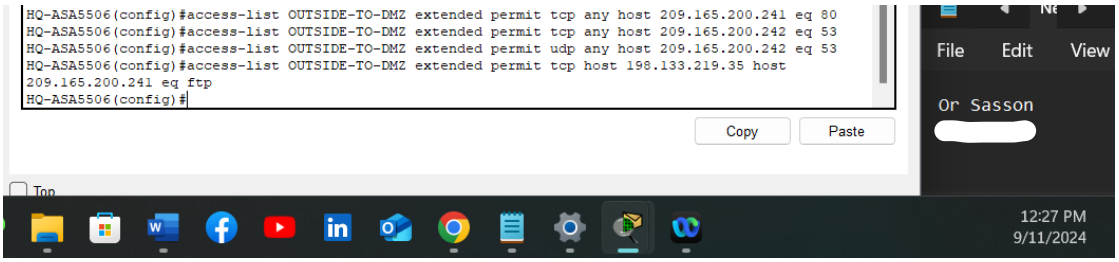


b) Apply NAT-IP-ALL ACL to the DMZ and OUTSIDE interfaces in the inward direction.



c) Configure an ACL to allow access to the DMZ servers from the internet. Create an extended named ACL (named OUTSIDE-TO-DMZ) to filter incoming traffic to the HQ ASA. The ACL statements should be created in the order specified in the following guidelines:

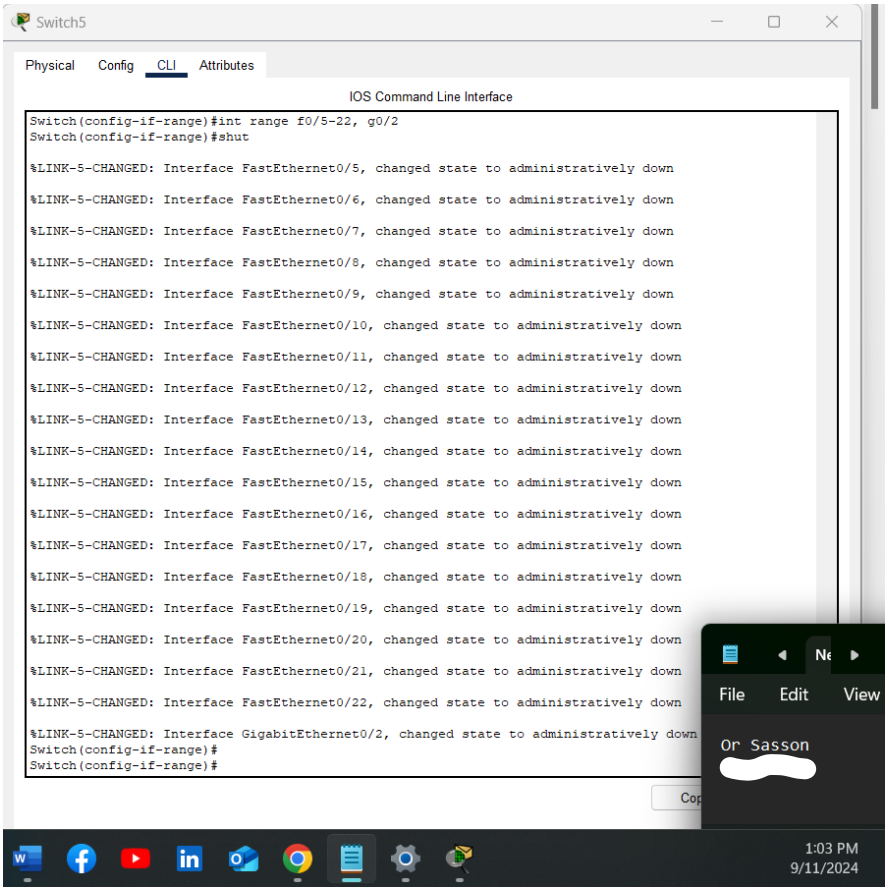
i. The ACL should contain four access control entries (ACEs).
ii. HTTP traffic is allowed to DMZ Web Svr.
iii. DNS traffic (both TCP and UDP) is allowed to the DMZ DNS server (two separate ACEs).
iv. FTP traffic from the Branch administrator workstation is allowed to the DMZ web server.
v. Show screenshots of list i to iv.



(B10) – Configure Layer 2 Security on a Switch

For this part of the assessment, you will be configuring Switch1 in the internal network with Layer 2 attack mitigation measures.

a) Disable Unused Switch Ports
   i. Disable all unused switch ports on Switch1.
   ii. Configure all unused ports in static access mode so that they will not negotiate trunks.



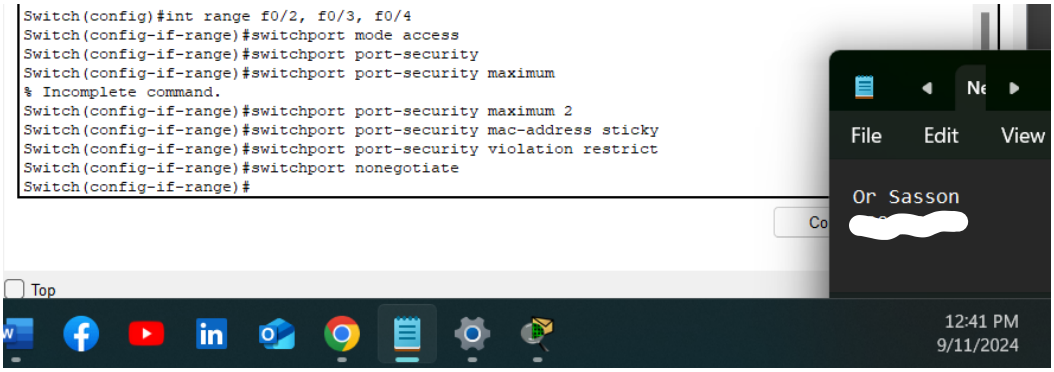


OFFICIAL

b) Implement Port Security

On Switch1, configure port security on all of the switch ports that are connected to hosts according to the following requirements:

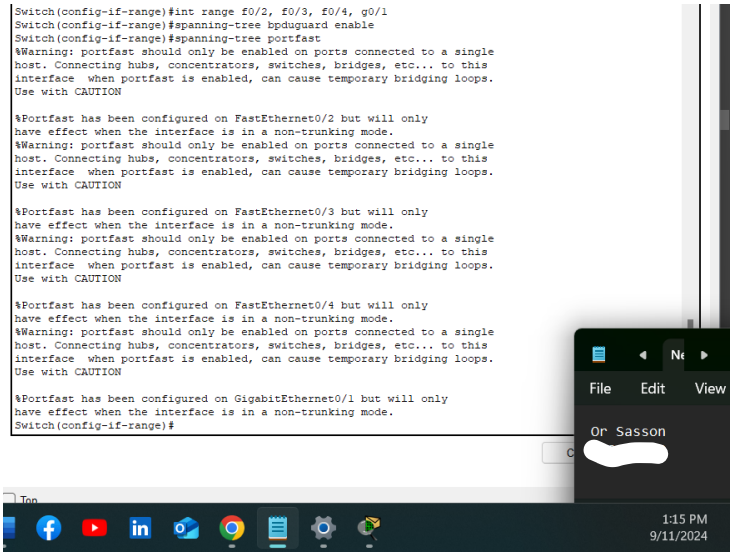
i. The ports should be configured as static access ports.
ii. The ports should learn a maximum of two MAC addresses.
iii. The ports should record the MAC addresses that have been learned in the device running configuration.
iv. If a violation occurs, the port should drop packets from host MAC addresses that have not been learned, increment the violation counter, and generate a syslog message.



c) Implement STP Security

On Switch1, implement STP security measures on the active ports that are connected to hosts.

i. Configure the switch to disable host ports that receive a BPDU.
ii. Configure the ports to quickly go into STP forwarding mode without going through the STP transitional modes. Do this on a port-by-port basis, not on the entire switch.

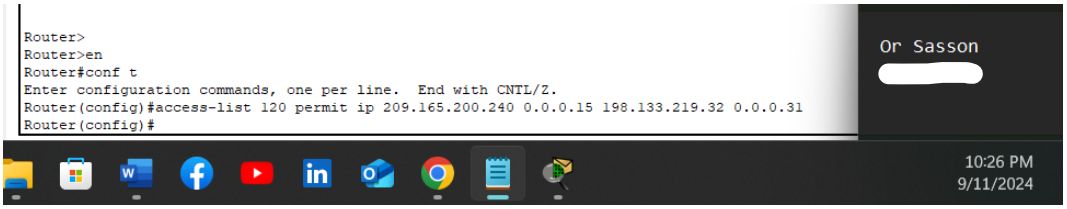


OFFICIAL

(B11) – Configure a Site-to-Site IPSEC VPN between the HQ and Branch routers.

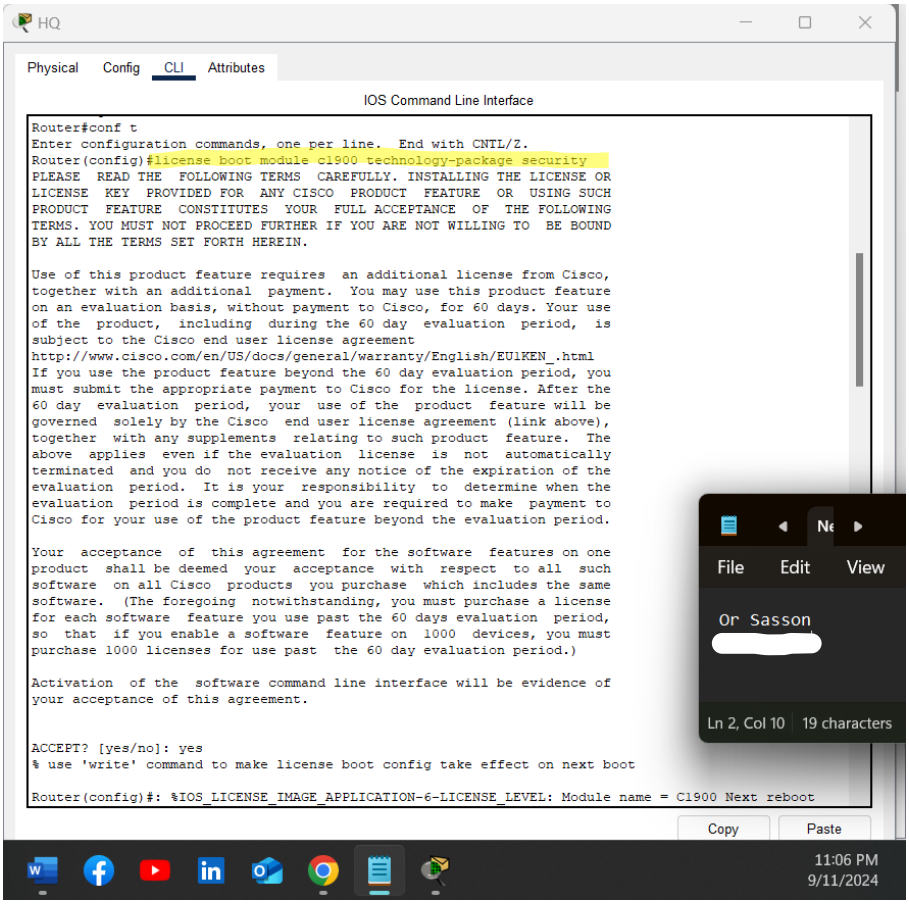
Please refer to the ISAKMP Phase 1 Policy Parameters and IPSEC Phase 2 Policy Parameters Tables provided in the Case study document.

a) Configure ACL 120 on the HQ router to identify the interesting traffic to be sent across the VPN. The interesting traffic is all IP traffic from the HQ LAN to the Branch LAN.

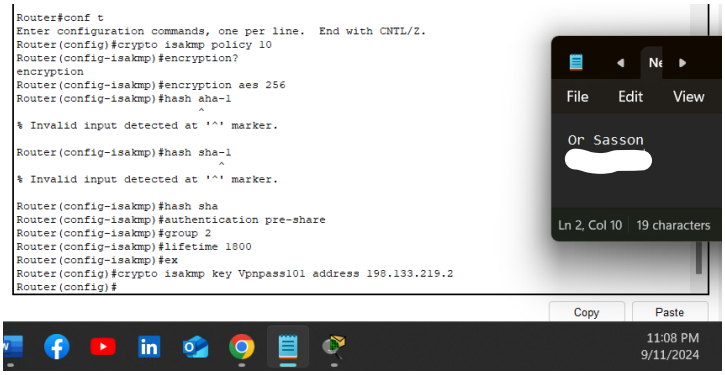


b) Configure the ISAKMP Phase 1 properties on the HQ router. The crypto ISAKMP policy is 10.

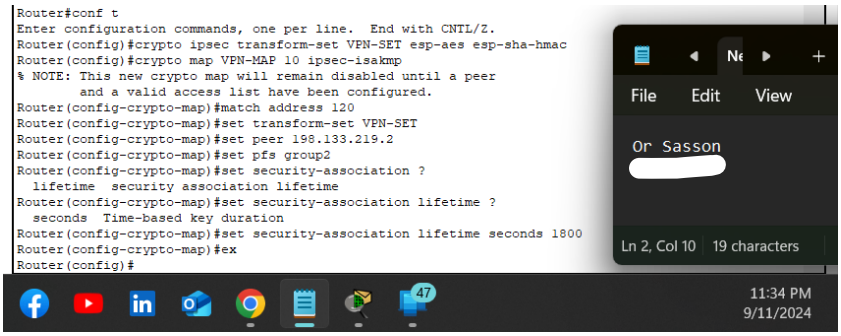
Firstly, I had to update the router with the license with the security package



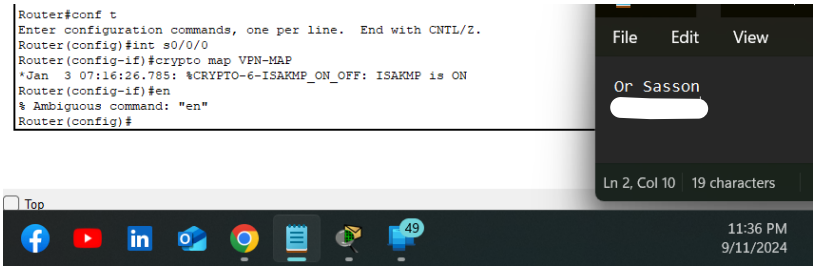
OFFICIAL



c) Configure the ISAKMP Phase 2 properties on the HQ router using 10 as the sequence number.

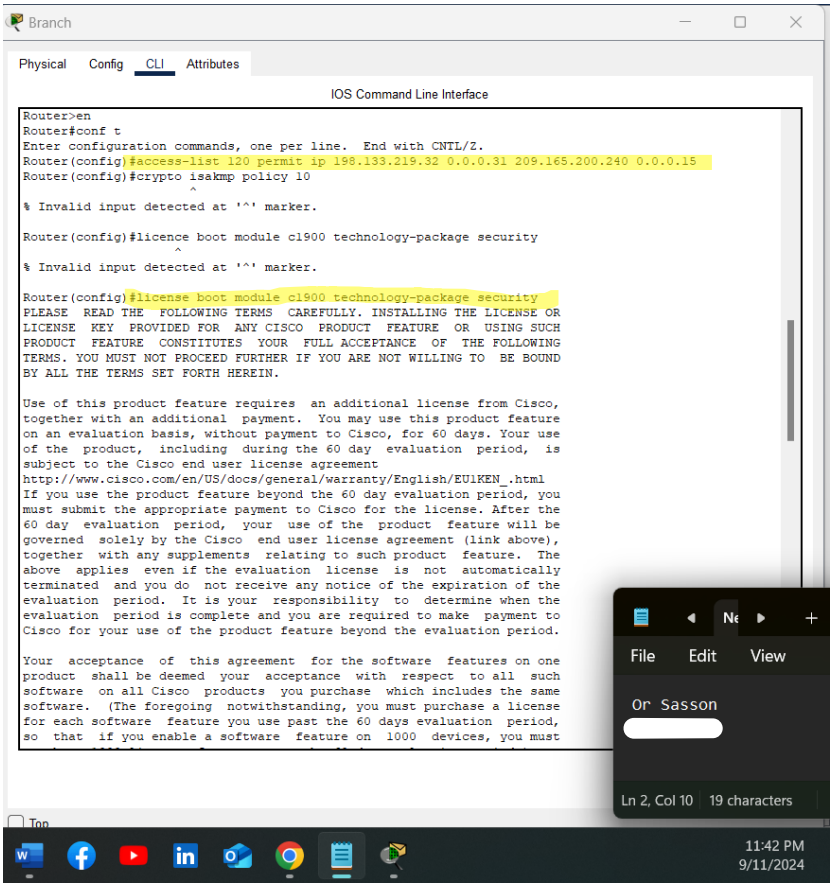


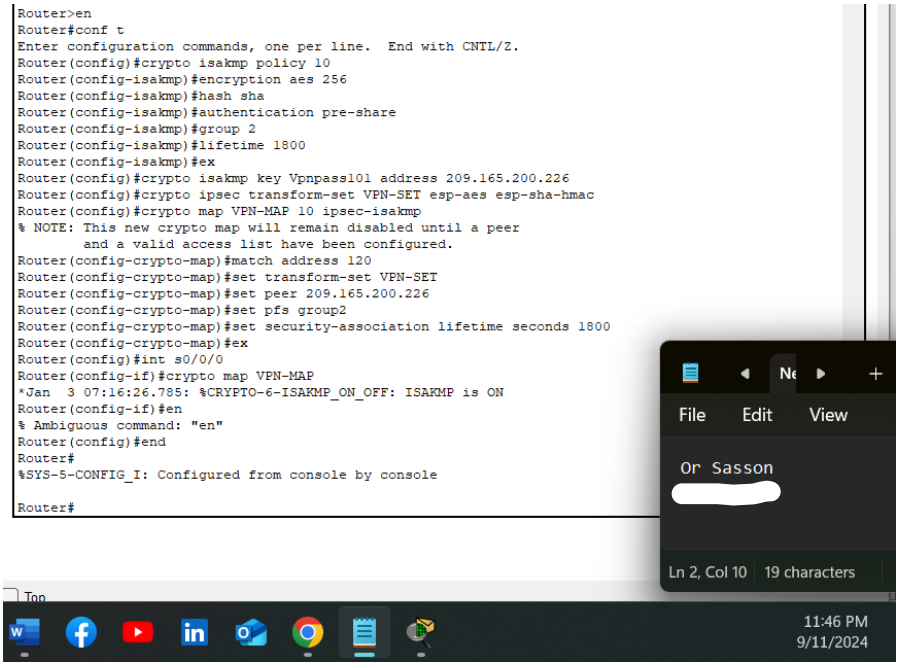
d) Bind the VPN-MAP crypto map to the outgoing interface.



e) Configure IPsec parameters on the Branch router using the same parameters as on the HQ router. Note that interesting traffic is defined as the IP traffic from the Branch LAN to the LAN that is attached to HQ.

OFFICIAL


Branch
Physical
Config
CLI
Attributes
IOS Command Line Interface
Router>en
Router#conf t
Enter configuration commands, one per line. End with CNTL/Z.
Router(config)#access-list 120 permit ip 198.133.219.32 0.0.0.31 209.165.200.240 0.0.0.15
Router(config)#crypto isakmp policy 10
% Invalid input detected at '^' marker.
Router(config)#licence boot module c1900 technology-package security
% Invalid input detected at '^' marker.
Router(config)#license boot module c1900 technology-package security
PLEASE READ THE FOLLOWING TERMS CAREFULLY. INSTALLING THE LICENSE OR
LICENSE KEY PROVIDED FOR ANY CISCO PRODUCT FEATURE OR USING SUCH
PRODUCT FEATURE CONSTITUTES YOUR FULL ACCEPTANCE OF THE FOLLOWING
TERMS. YOU MUST NOT PROCEED FURTHER IF YOU ARE NOT WILLING TO BE BOUND
BY ALL THE TERMS SET FORTH HEREIN.
Use of this product feature requires an additional license from Cisco,
together with an additional payment. You may use this product feature
on an evaluation basis, without payment to Cisco, for 60 days. Your use
of the product, including during the 60 day evaluation period, is
subject to the Cisco end user license agreement
http://www.cisco.com/en/US/docs/general/warranty/English/EU1KEN_.html
If you use the product feature beyond the 60 day evaluation period, you
must submit the appropriate payment to Cisco for the license. After the
60 day evaluation period, your use of the product feature will be
governed solely by the Cisco end user license agreement (link above),
together with any supplements relating to such product feature. The
above applies even if the evaluation license is not automatically
terminated and you do not receive any notice of the expiration of the
evaluation period. It is your responsibility to determine when the
evaluation period is complete and you are required to make payment to
Cisco for your use of the product feature beyond the evaluation period.
Your acceptance of this agreement for the software features on one
product shall be deemed your acceptance with respect to all such
software on all Cisco products you purchase which includes the same
software. (The foregoing notwithstanding, you must purchase a license
for each software feature you use past the 60 days evaluation period,
so that if you enable a software feature on 1000 devices, you must
File
Edit
View
Or Sasson
[redacted]
Ln 2, Col 10
19 characters
Top
11:42 PM
9/11/2024

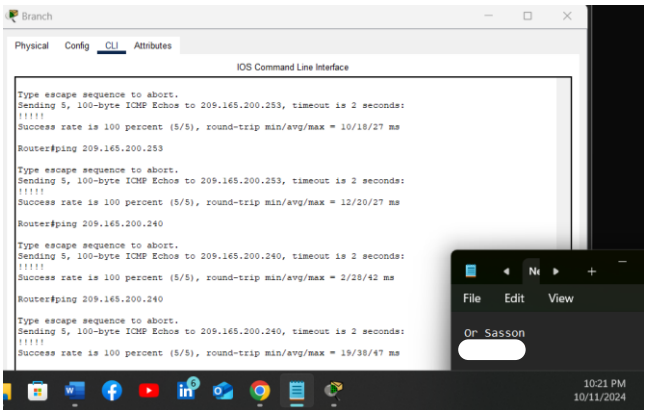

Router>en
Router#conf t
Enter configuration commands, one per line. End with CNTL/Z.
Router(config)#crypto isakmp policy 10
Router(config-isakmp)#encryption aes 256
Router(config-isakmp)#hash sha
Router(config-isakmp)#authentication pre-share
Router(config-isakmp)#group 2
Router(config-isakmp)#lifetime 1800
Router(config-isakmp)#ex
Router(config)#crypto isakmp key Vpnpass101 address 209.165.200.226
Router(config)#crypto ipsec transform-set VPN-SET esp-aes esp-sha-hmac
Router(config)#crypto map VPN-MAP 10 ipsec-isakmp
% NOTE: This new crypto map will remain disabled until a peer
and a valid access list have been configured.
Router(config-crypto-map)#match address 120
Router(config-crypto-map)#set transform-set VPN-SET
Router(config-crypto-map)#set peer 209.165.200.226
Router(config-crypto-map)#set pfs group2
Router(config-crypto-map)#set security-association lifetime seconds 1800
Router(config-crypto-map)#ex
Router(config)#int s0/0/0
Router(config-if)#crypto map VPN-MAP
*Jan 3 07:16:26.785: %CRYPTO-6-ISAKMP_ON_OFF: ISAKMP is ON
Router(config-if)#en
% Ambiguous command: "en"
Router(config)#end
Router#
%SYS-5-CONFIG_I: Configured from console by console
Router#
File
Edit
View
Or Sasson
[redacted]
Ln 2, Col 10
19 characters
Top
11:46 PM
9/11/2024

OFFICIAL

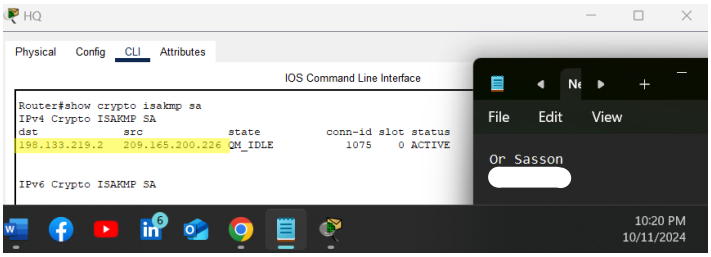
(B12) – VPN Monitoring

a) Create interesting traffic by pinging from Branch LAN to the LAN attached to HQ. Use the command show crypto isakmp sa and take the screenshot of the destinations and source IP addresses.

I was pinging from the Branch router to the 209.165.200.240 which attached to HQ and to the 209.165.200.253 which attached to the ASA device

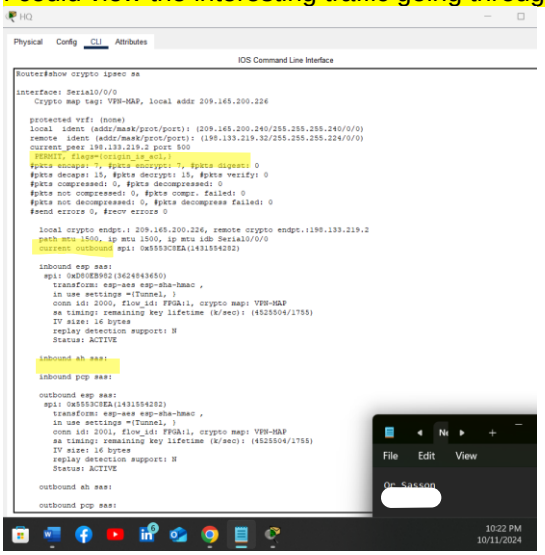


Then, I was able to monitor the show crypto isakmp sa command information



b) Use the command show crypto ipsec sa to check the encapsulated, encrypted, decapsulated and decrypted traffic. Troubleshoot if you didn't get the expected result.

I could view the interesting traffic going through the tunnel on the HQ router



OFFICIAL